BLE fundamentals

- for sending small amt of data infrequently
- low power
  - ↳ smart lighting, smart homes, beacons, fitness trackers, etc..

Bluetooth profile defines how it is used.
ie. headset profile, human interface device (HID), etc.

BLE profiles:

https://lastminuteengineers.com/esp32-ble-tutorial/

GAP (Generic Access Profile)

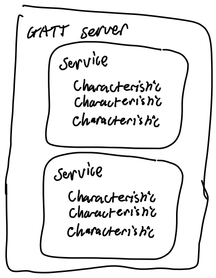
- defines connection and advertising

- peripheral devices
- usually small, low power, resource constrained device.
- connects to more powerful central device.

- advertises by sending out advertising packets at set intervals.
- once connection established, advertising stops and GATT happens.

In project,
phone is the central,
ESP32 is peripheral

-central devices
- more processing/memory
- like mobile phones or tablets to which u connect



phone is server
esp32 is client

↳ for setup:
APPLE blocks 3rd party from initiating connection to iphone. so iphone has to initiate (act as client, scan for esp32) & esp32 acts as server because phone taps into it. after that it reverses.

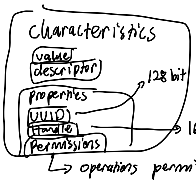
GATT (generic attribute profile)

- defines how data organized / how BLE devices share data
- organized into **service** hierarchically, grouping conceptually related **characteristics**.

- Services
  - has unique numeric identifier (UUID) → usually 16 bits
  - ex: ANCS (apple notification center service)
    Find my network service
    Heart rate
    Cycling speed and cadence

- server: device that contains characteristic database.
- client: reads / writes data to GATT server.

GATT client $\xrightarrow{\text{request/command}}$ GATT server
$\xleftarrow{\text{responds}}$



128 bit
16 bit (to access characteristic)
↳ operations permitted, like read, write or notify

- value is actual data stored in characteristic
  (number, string, bytes, etc)
- descriptor
  - additional info/config

Securing BLE devices

pairing - security/exchange keys, creates encrypted session for current connection (Short term key) STK
bonding - stores keys produced during pairing so future connections can start encrypted/authenticated without repairing. (Long term key - LTK)

types of attacks:
- passive eavesdropping
- active eavesdropping (man in the middle)
  - ↳ device impersonates both devices on each side, intercepting communication
- identity tracking

- security manager (SM)
  - define protocols and communications used for generating and exchanging keys to secure comm.

initiator ⟷ established link layer connection ⟷ responder

Pairing
- **Phase 1: Pairing request/response.** (introduction/swapping capabilities)
  - decide on pairing method ie. Just Works.
- **Phase 2: STK/LTK generation**
  - pair over legacy pairing or modern LE Secure Connection.

features exchanged b/w 2 devices during phase 1:
- i/o capabilities (display/keyboard?, etc)
- OOB flag
- authentication requirement
  - ↳ bonding requested? support of secure connection? MITM?

↓

Bonding
- after this all subsequent data are encrypted.
- save LTKs / IRK / MAC addresses into non volatile memory (flash storage)

legacy connection → Legacy Connection:
- STK
- Just Works - temporary key set to 0
- OOB (out of band) - TK exchanged over not BLE
- passkey - TK is 6 digit

secure connection (sc flag = true)
- LTK

↳ pairing methods:
- Just Works - public key exchanged over BLE.
- OOB
- Passkey
- Numeric comparison: same as Just Works but adds an extra step.

Phase 3: if bonding:
2 keys:
IRK (identity resolving key) → to resolve changing private address
CSRK

https://www.youtube.com/watch?v=ZpOmzx-pyns&start=301
part 1 + 2

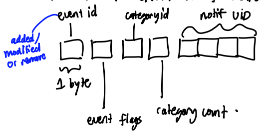
ANCS (Apple Notif Center Service)

3 characteristics:

1) Notification Source

- inform new IOS notif, modify IOS notif or removal of notif

format of GATT notif delivered through Notif Source characteristic



2) Control Point and Data Source

- write only characteristic to send instructions back to host device
- to ask for details
  - write a command structure into control point

    ex. give title & message

If write command to Control point characteristic is successful, the Data Source characteristic will send actual stream of GATT notifications.

Callbacks

- function that runs later when specific event happens.
- nonblocking, let program do other things until event actually occurs